

OWASP TOP 10 - VULNÉRABILITÉS WEB

=====

1. INJECTION (SQL, NoSQL, OS)

- Utiliser des requêtes paramétrées
- Valider et sanitizer les inputs
- Utiliser des ORM avec protection

2. BROKEN AUTHENTICATION

- Implémenter MFA
- Limiter les tentatives de login
- Utiliser des tokens JWT sécurisés

3. SENSITIVE DATA EXPOSURE

- Chiffrer les données sensibles
- Utiliser HTTPS partout
- Ne pas stocker de données inutiles

4. XML EXTERNAL ENTITIES (XXE)

- Désactiver l'expansion d'entités XML
- Utiliser des formats plus sûrs (JSON)
- Valider les XML entrants

5. BROKEN ACCESS CONTROL

- Implémenter le principe du moindre privilège
- Valider les permissions côté serveur
- Journaliser les accès

OUTILS DE DÉTECTION

- OWASP ZAP pour DAST

- Bandit pour SAST Python
- Dependency-Check pour SCA
- TruffleHog pour détection de secrets

PRÉVENTION

- Intégrer les tests dans CI/CD
- Formation continue des développeurs
- Revue de code sécurité
- Pentesting régulier